CR-2026-00096 — End-to-End Walkthrough

Launch Prepaid Settlement Card | HumAId Risk Governance — Risk Assessment Workbench | Audience: QA and team members
Source: Azure dev database (`risk_governance_db`) restored from the 8 Oct 2026 backup. All data is synthetic.

> **Purpose.** This document follows one real change request from intake to committee vote. For each step it shows what the user does, what the system or AI does, what is stored, and which configuration drives it. QA can use it as a reference run and a template for regression tests.
> **Golden rule:** the system prepares, humans decide. Nothing is auto-approved or auto-rejected.

1. Request at a glance

Field	Value
Request number	CR-2026-00096
Title	Launch Prepaid Settlement Card
Change type	Product (new product)
Description	New reloadable prepaid debit card for retail and small-business customers, with domestic and cross-border POS/ATM transactions.
Type-specific details	Card processing via third-party processor (QuickPay Processing Ltd); fully online onboarding, no branch visit required.
Submitted	30 Sep 2026, 11:15 UTC (Product Owner role)
Current status	**PendingCommittee** — assessment Finalized, 1 of 2 required votes cast (Approve)
Attachment (used)	`product-launch-brief-Prepaid-Settlement-Card.pdf` (v1)

2. Lifecycle overview

#	Stage	Role	Who acts	Time (UTC, 30 Sep)
1	Intake: create request, snapshot from mock systems, upload brief	Product Owner	Human + System	11:15 – 11:23
2	Risk categorisation (FFIEC)	Analyst	AI proposes, Human overrides	11:37 – 11:50
3	Policy research	Analyst	Deterministic search, Human decides	12:12 – 12:15
4	Document extraction	Analyst	AI extracts, Human corrects	12:22 – 12:29
5	Narrative drafting and review	Analyst	AI drafts, Human edits and reviews	12:29 – 12:37
6	Risk scoring	Analyst	Deterministic formula	12:45 – 12:47
7	Finalise assessment and route to committee	Analyst	Human	12:57 – 12:58

8	Committee vote	Committee member	Human	13:04
9	Immutable audit trail and SLA tracking (throughout)	—	System	all stages

3. Step-by-step

Step 1 — Intake (Product Owner)

1. Product Owner creates a change request and picks the change type **Product**. The system assigns `CR-2026-00096`.
2. On creation the Data Ingestion Layer pulls context from the **Mock External Systems** service (CRM / Core Banking / Vendor Management). It is the only path to that service. The result is stored in `change_request_external_snapshot` and audited as *Ingested / ExternalSnapshot* (system).
3. Product Owner uploads the product launch brief PDF. Text is extracted and stored in `change_request_attachment.extracted_text`; the file goes to blob container `change-request-attachments`. Audit: *Uploaded / Attachment*.

QA checks: request number format; snapshot row exists; attachment is versioned (`version_number`); audit rows exist for each action.

> **Data note:** the ingested snapshot for this request shows *Prepaid Travel Card / UAE* (a mock-system record), which does not exactly match the request. This is a quirk of the synthetic mock data and a good negative test (the analyst must rely on the brief, not the snapshot).

Step 2 — Risk categorisation (US-2.x) AI + Human

1. Rule-based default: `change_request_type_category_map` maps **Product → Products & Services (Primary) + Customers & Entities (Secondary)**.
2. The AI (`CategoryMappingAiClient`) proposes categories from the FFIEC BSA/AML framework only (no invented categories) with a citation. Two AI proposals were audited (*AiProposed / CategoryMapping*).
3. The analyst overrode the mapping with a stated reason each time (6 override events). The AI proposal is kept; the override is stored beside it, never in place.

Category	Source	Active	Note
PRODUCTS_SERVICES	AiProposed	Yes	AI citation: FFIEC manual, Products and Services
GEOGRAPHIC_LOCATIONS	AnalystAdded	Yes	Added because of 12 countries incl. 2 FATF-monitored
CUSTOMERS_ENTITIES	AnalystAdded	Yes	Added because of cash-intensive small businesses
DELIVERY_CHANNELS	AnalystAdded	No (removed)	Removed again: reason "not applicable"

QA checks: an override without a reason is rejected; original AI row remains; removal is a soft state (`is_active=false`), not a delete.

Step 3 — Policy research (US-3.x) Deterministic + Human

1. The system runs a full-text search (`policy_chunk.search_vector`) over the local corpus of FFIEC policy chunks. There are no live internet calls and no LLM here: a deliberate engineering choice (retrieval is deterministic and citable).
2. The analyst decides on each suggested chunk: **Relied upon** or rejected. Two decisions were recorded (*Decided / PolicyReliance*). The final state holds one reliance: FFIEC BSA/AML Examination Manual — *Prepaid Access Customers* (Customers & Entities).

QA checks: only chunks the analyst relied on can be cited in the narrative; each decision is audited with the user.

Step 4 — Document extraction (US-4.x) AI + Human

1. The AI (`DocumentExtractionAiClient`) extracts structured fields from the PDF text, each with a source excerpt and a confidence score. Low-confidence or ambiguous fields are flagged `needs_review = true`.
2. Here 13 fields were extracted (product name, description, target customers, transaction types, cross-border scope, onboarding channel, third-party vendor, data handled, etc.).
3. **Flagged:** `fatf_monitored_jurisdictions_count = "two"` (confidence 0.60, needs review).
4. **Human correction:** the analyst corrected the data exchange method to "*SFTP-based daily settlement file exchange (not real-time API)*". Reason: "*Vendor kickoff call confirmed batch is SFTP, not real-time API.*" The row is marked `AnalystCorrected`; the AI's original value is kept in the audit event.

QA checks: low confidence gives needs_review; a correction needs a reason; original AI value is retrievable.

Step 5 — Narrative drafting and review (US-5.x / 6.x) AI + Human

1. The AI (`NarrativeDraftingAiClient`) drafts one narrative section per active category, grounded only in the extracted fields and the policy chunks the analyst relied on. It must not invent facts; anything it cannot support goes into `unsupported_claim_flags` instead of the text.
2. Four drafts were generated (*AiDrafted / NarrativeSection*).

Section	Final status	Unsupported-claim flags
Products & Services	AnalystReviewed	none
Customers & Entities	AnalystReviewed	none
Geographic Locations	AnalystEdited	2 flags: (a) "QuickPay has adequate controls…", (b) "Ongoing monitoring is sufficient…". The AI flagged these as claims it could not support.

3. Analyst edited the geographic section to name the two FATF-monitored jurisdictions. Reason: "*Added explicit mention of the two FATF-monitored jurisdictions per FCR…*" Audit: *AnalystEdited*.
4. Analyst marked the other two sections *Reviewed*. **Review gate:** an unreviewed narrative cannot reach the committee.

Step 6 — Risk scoring (US-7.x) Deterministic, no AI

Formula: `Residual = Inherent − (Control Effectiveness × Mitigation Factor)`. The mitigation factor is capped below 1.0 (config: `scoring_config.max_mitigation_factor = 0.85` for every category), so residual risk can never reach zero. This is enforced in the calculation **and** when the analyst saves the configuration.

Category	Inherent	Control effectiveness	Mitigation factor	Residual	Check
Products & Services	4.00	0.600	0.850	**3.49**	4 − 0.6×0.85 = 3.49
Customers & Entities	3.00	0.650	0.850	**2.45**	3 − 0.65×0.85 = 2.4475
Geographic Locations	4.00	0.700	0.850	**3.41**	4 − 0.7×0.85 = 3.405

All three rows have `scored_by = System`, no override. If an analyst overrides a score, the system stores the original and the new value plus a mandatory reason (`is_override`, `override_reason`).

QA checks: recompute each residual by hand; try to save a mitigation factor ≥ 1.0 (must be rejected); residual always > 0.

Step 7 — Finalise and route to committee (Analyst)

1. The analyst finalises the assessment (status **Finalized**, 12:57 UTC) and routes the request. Request status changes to **PendingCommittee**. Audit: *Finalized / Assessment*, *Routed / ChangeRequest*.
2. The SLA clock for the stage starts: `change_request_stage_history` shows stage PendingCommittee, target 5 business days, entered 30 Sep 12:57.

Step 8 — Committee review and voting (US-8.x) Human

1. A committee member (`committee1@example.bank`) reviews the finalised assessment and votes **Approve** (13:04 UTC).
2. Decision rule (workflow config): `workflow_rule CommitteeQuorum = {"quorum": 2}`. A decision (`committee_decision`) is created only after 2 votes. At present there is **1 vote and no decision**, so the request stays PendingCommittee.
3. Possible outcomes: Approved, Rejected, Deferred, Approved with conditions. Defer / conditions need a rationale. On decision the result is pushed back to the source system by a deterministic call (no AI).

QA checks: a second vote reaches quorum and creates the decision; a member cannot vote twice; non-committee roles get HTTP 403.

Step 9 — Audit trail and SLA (cross-cutting)

- **Audit:** 51 audit events for this request. The `audit_event` table is append-only at the database level (a trigger blocks UPDATE and DELETE); there is no update or delete path in the app. Each event stores actor (human, system or system/AI), before and after values and the reason.
- **SLA:** business-day targets per stage and change type from `sla_target`, with holidays in `sla_holiday`. SLA only informs; a breach never changes a status or makes a decision.

Later events (1 Oct and 25 Oct) are a second upload, re-extraction and a re-route done while testing.

4. How it is configured

Area	Where	Value for this run

Risk framework	`risk_framework`, `risk_category`, `risk_subfactor`	FFIEC BSA/AML Examination Manual: 4 categories (Products & Services, Customers & Entities, Geographic Locations, Delivery Channels)
Type → category map	`change_request_type_category_map`	Product: Products & Services (Primary), Customers & Entities (Secondary)
Scoring cap	`scoring_config` (versioned, with reason)	max mitigation factor 0.85 for every category
Controls library	`control`	14 controls, e.g. "Prepaid access load limits", "OFAC sanctions screening", "Non-face-to-face identity verification"
Committee quorum	`workflow_rule` (CommitteeQuorum)	2 votes
SLA	`sla_config`, `sla_target`, `sla_holiday`	PendingCommittee target: 5 business days
Policy corpus	`policy_document`, `policy_chunk`	Public FFIEC text, chunked, full-text indexed (no live fetch)
AI provider	env `AI_PROVIDER`	Anthropic (local) or AzureFoundry (Azure dev)
Prompts	`ai/prompts/`	category mapping, document extraction, narrative drafting
Access control	Auth0 JWT + `app_user_role`	ProductOwner, Analyst, CommitteeMember, Admin; enforced at the API (see `docs/governance/access-control-matrix.md`)

Configuration changes are made by an analyst in the Configuration screens, need a reason, and create a new version (old rows are kept inactive), so any past rating can be reconstructed for examiners.

5. Where AI is used and where it is not

Step	AI?	Human gate
Category mapping	Yes — proposes	Analyst confirms / overrides with reason
Policy research	No — full-text search	Analyst decides reliance
Document extraction	Yes — extracts	Analyst corrects flagged fields
Narrative	Yes — drafts	Analyst edits, reviews (required)
Scoring	No — formula	Analyst may override with reason
Committee decision	No	Members vote
Audit, SLA, push-back to source	No	—

6. Suggested QA test ideas from this run

1. Happy path: replay all steps with a fresh request and compare to the table in section 2.
2. Human override without a reason is rejected (categories, extraction, narrative, score).
3. AI output is never overwritten: original and override both retrievable.

4. Narrative with unsupported-claim flags: analyst must review before finalising.
5. Residual risk is above zero for any inputs; mitigation config ≥ 1.0 is rejected.
6. Quorum: 1 vote leaves PendingCommittee; 2nd vote produces the decision.
7. Audit table: direct UPDATE / DELETE fails at the database level.
8. Role checks: Product Owner cannot finalise; Analyst cannot vote; every restricted API returns 403.
9. Edge: the mismatching mock snapshot and the low-confidence field are handled by the analyst, not silently accepted.

Generated 26 Oct 2026 from live dev DB data. Related docs: `docs/requirements/user-stories.md`, `docs/governance/`, `evals/README.md`, `ops/db-backup/README.md`.